# LAPORAN PENETRATION TESTING

Evaluasi Keamanan Infrastruktur dan Aplikasi Web

---

**Klien** : PT NutWear

**Target Pengujian** : OWASP Juice Shop & Metasploitable2

**Metodologi** : Penetration Testing Execution Standard (PTES)

## 1. EXECUTIVE SUMMARY

Dokumen ini berisi laporan hasil pengujian keamanan (penetration testing) yang dilakukan terhadap aplikasi web OWASP Juice Shop dan server Metasploitable2. Pengujian ini bertujuan untuk mengidentifikasi celah keamanan pada sistem dan memberikan rekomendasi perbaikan secara terstruktur sebelum celah tersebut dapat disalahgunakan oleh pihak yang tidak bertanggung jawab.

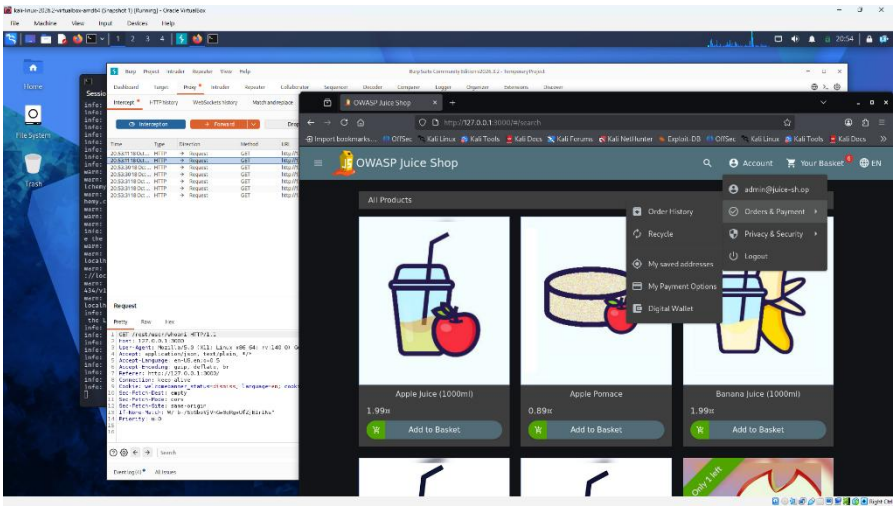
Berdasarkan hasil pengujian, ditemukan 4 (empat) kerentanan utama. Terdapat 3 kerentanan pada aplikasi web dengan ragam tingkat risiko (SQL Injection, Broken Access Control, dan Cross-Site Scripting), serta 1 kerentanan berisiko kritis pada infrastruktur server yang memungkinkan pengambilalihan sistem secara penuh (akses root).

## 2. TECHNICAL DETAILS

### A. Temuan pada Aplikasi Web (OWASP Juice Shop)

**Temuan 1: SQL Injection (Bypass Autentikasi)**

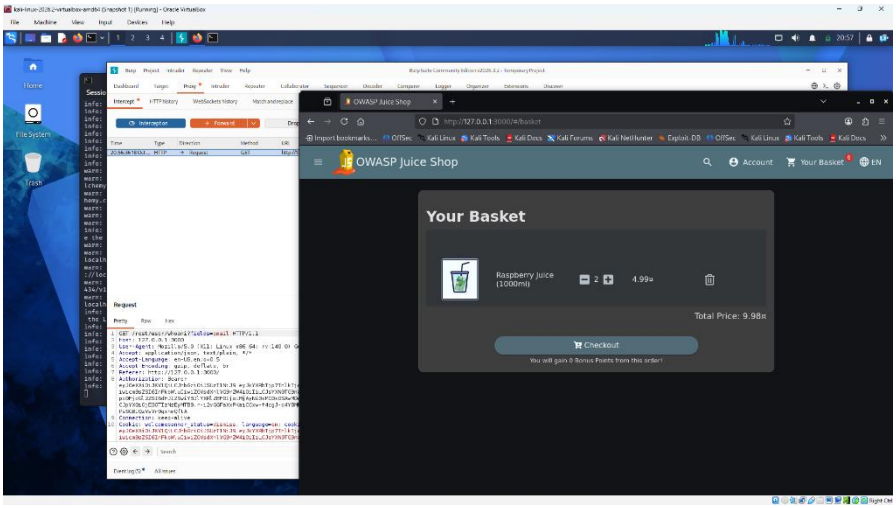
- **Severity Rating:** Kritis (Critical)
- **Impact:** Penyerang dapat menembus portal login dan masuk ke akun Administrator tanpa perlu mengetahui kata sandi, sehingga mendapat akses penuh ke fitur manajerial aplikasi web.
- **Proof of Concept (PoC):** Pada form login utama, parameter email dimanipulasi dengan payload `' OR 1=1--`. Sintaks ini memicu anomali pada query database sehingga sistem memvalidasi sesi dan langsung memberikan akses ke akun pengguna pertama (admin@juice-sh.op).



- **Remediation:** Implementasikan *parameterized queries* atau *prepared statements* pada sisi backend (Node.js/Express). Hindari penggabungan string secara langsung agar input dari pengguna tidak dieksekusi sebagai perintah SQL aktif.

**Temuan 2: Broken Access Control (IDOR)**

- **Severity Rating:** Tinggi (High)
- **Impact:** Penyerang dapat melihat dan memanipulasi isi keranjang belanja milik pengguna lain, yang berpotensi menyebabkan kebocoran data transaksi secara masif.
- **Proof of Concept (PoC):** Saat mengakses halaman keranjang belanja, request API diintersepsi menggunakan proksi HTTP. Parameter URL `/rest/basket/1` diubah secara manual menjadi nilai milik entitas lain, misalnya `/rest/basket/2`. Server tetap memproses permintaan tersebut tanpa memvalidasi kepemilikan objek, menampilkan data keranjang ID lain.




- **Remediation:** Terapkan validasi otorisasi di tingkat backend. Pastikan identitas yang terenkapsulasi dalam token sesi (JWT) benar-benar cocok dengan ID objek/keranjang yang diminta sebelum data dikembalikan ke peramban klien.

**Temuan 3: Cross-Site Scripting (Reflected XSS)**

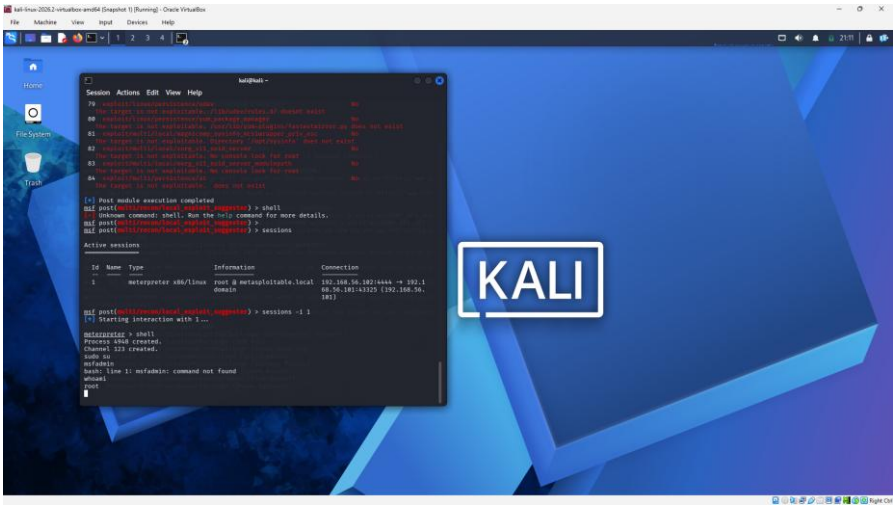
- **Severity Rating:** Menengah (Medium)
- **Impact:** Penyerang dapat menyisipkan skrip berbahaya yang akan dieksekusi oleh peramban pengguna lain, memungkinkan pencurian kuki sesi atau pengalihan halaman secara paksa.
- **Proof of Concept (PoC):** Pada fitur pencarian produk, input diisi dengan payload `<iframe src="javascript:alert('xss')">`. Aplikasi memantulkan (reflect) input tersebut kembali ke halaman hasil pencarian tanpa penyaringan, sehingga memicu eksekusi skrip di sisi klien.
- **Remediation:** Terapkan sanitasi input yang ketat dan pastikan setiap data yang direnderer ke antarmuka pengguna telah melalui proses *HTML entity encoding*.

**B. Temuan pada Server Infrastruktur (Metasploitable2)**

**Temuan 4: FTP vsftpd 2.3.4 Backdoor**

- **Severity Rating:** Kritis (Critical)

- **Impact:** Celah ini mengizinkan penyerang mengeksekusi perintah sistem dari jarak jauh (Remote Code Execution), menghasilkan akses kendali penuh dengan hak istimewa tertinggi (root) pada server.
- **Proof of Concept (PoC):** Fase reconnaissance mengidentifikasi port 21 yang terbuka dengan layanan `vsftpd 2.3.4`. Layanan ini diketahui mengandung celah backdoor bawaan. Menggunakan Metasploit Framework, modul `exploit/unix/ftp/vsftpd_234_backdoor` dieksekusi terhadap target. Modul berhasil memicu backdoor dan membuka sesi interaktif yang divalidasi melalui eksekusi perintah `whoami` (mengembalikan nilai root) dan pembacaan berkas `/etc/shadow`.
- **Remediation:** Lakukan isolasi server secara instan. Perbarui atau ganti daemon FTP ke versi mutakhir yang bebas dari backdoor. Sangat direkomendasikan untuk menonaktifkan protokol




FTP usang (port 21) dan memigrasikan transfer berkas internal ke protokol aman yang dienkripsi secara penuh, seperti SFTP.\